

CYBER SECURITY INCIDENT RESPONSE PLAN

Derived from SANS Institute Cybersecurity Sample Policies and Public Domain Sources

Prepared by Noe Valencia | March 22, 2026

Version	Effective Date	Document Owner	Status
1.0	March 22, 2026	Noe Valencia	Active

Do not distribute externally.

1. Goals for Cyber Incident Response

When a cybersecurity incident occurs, timely and thorough action to manage its impact is critical to an effective response. The response must limit potential damage by ensuring actions are well known, coordinated, and executed consistently. The goals of this plan are:

1. Preserve and protect the confidentiality of employee and constituent information, and ensure the integrity and availability of all organizational systems, networks, and data.
2. Help organizational personnel recover their business processes following a computer or network security incident or data breach.
3. Provide a consistent, repeatable response strategy to system and network threats that put organizational data and systems at risk.
4. Develop and activate a communications plan including initial reporting of the incident and ongoing communications as necessary throughout the response lifecycle.
5. Address cyber-related legal issues including regulatory notification obligations, contractual requirements, and potential law enforcement engagement.
6. Coordinate efforts with external Computer Incident Response Teams, forensic vendors, and law enforcement as appropriate.
7. Minimize organizational reputational risk through controlled, timely, and accurate communications.

2. Purpose and Scope

This plan provides practical guidelines for responding to cybersecurity and data breach incidents in a consistent and effective manner. It establishes a team of first responders known as the Incident Response Team (IRT), with defined roles, responsibilities, and communication protocols.

While this plan is primarily oriented around cyber-related incidents and breaches, it may also be utilized for data breaches not directly related to computer systems, such as physical theft of records or inadvertent disclosure of printed materials.

This plan applies to all personnel, systems, and data within the organization. All employees, contractors, and third-party service providers with access to organizational systems are subject to this plan and must cooperate fully with the IRT during an active incident.

3. Incident Response Team (IRT)

A team comprised of company staff, advisors, and service providers shall be responsible for coordinating incident responses. This team is known as the Incident Response Team (IRT). The IRT shall consist of both primary and secondary members. Primary members act as first responders and are engaged based on the severity of the incident. The entire team is activated for the most severe incidents.

There shall be a designated Incident Response Manager (IRM) who takes on organizational and coordination leadership of the IRT during an active incident. The IRM serves as the single point of coordination for all response activities.

IRT members may take on additional roles during an incident as needed. The IRT will draw upon Subject Matter Experts (SMEs) including IT staff, forensic vendors, legal counsel, and public relations advisors as required. Huntress serves as the organization's AI-powered managed

detection and response (MDR) provider and is a key SME for technical analysis, threat hunting, and initial containment guidance. A critical capability of Huntress is its automated endpoint quarantine feature: when a threat is detected, Huntress AI automatically isolates the affected end user's computer from the network, preventing the threat from spreading laterally to other systems or causing further damage while the IRT coordinates its full response. Contact information including primary and secondary email addresses, plus office and mobile phone numbers, shall be maintained and circulated to the team as confidential information.

3.1 Primary Team Members

Role	Assigned To	Primary Responsibilities
Head of Information Technology	Noe Valencia	Discover and verify incidents; notify IRT; coordinate forensic and technical remediation; apply corrective actions to infrastructure; maintain proactive cybersecurity posture
Incident Response Manager (IRM)	Noe Valencia	Coordinate communications and activities of the IRT when activated; serve as single point of coordination during active incidents
Executive Financial Manager	[Name / Title]	Assess financial impact and financial data exposure; authorize emergency expenditures for incident response
Executive Communications Manager	[Name / Title]	Manage public relations, news media, and all external and internal communications during an incident
Executive HR Manager	[Name / Title]	Manage communications to employees; address employee data exposure issues
Executive Operations Manager	[Name / Title]	Assess operational impact and overall data exposure; maintain business continuity during incident
Physical Security Manager	[Name / Title]	Manage building access, control, and physical security during an incident

3.2 Secondary Team Members

Role	Vendor / Contact	Primary Responsibilities
Security Monitoring / AI Detection (MDR)	Huntress	AI-powered threat detection; automatically quarantines affected endpoints upon threat detection to prevent lateral movement and network spread; technical mitigation and digital forensics support

Role	Vendor / Contact	Primary Responsibilities
Legal Representative	[Law Firm / Attorney]	Legal advisor; regulatory compliance; contractual matters; law enforcement liaison
Public Relations Vendor	[PR Firm Name]	External public relations advisor during and after significant incidents
Cyber Insurance Provider	[Insurance Provider]	Cyber insurance advisor; claims coordination; coverage guidance

4. Incident Response Lifecycle

Cyber incident response management is an ongoing process with a cyclical pattern. Each phase builds on the previous, and lessons learned from any incident are fed back into the preparation phase to continuously improve the organization's response capabilities. The seven phases of the lifecycle are:

Phase	Description
1. Preparation	The ongoing process of maintaining and improving incident response capabilities and preventing incidents through secure systems, employee awareness training, and periodic tabletop exercises. Huntress provides continuous AI-powered threat detection and managed detection and response (MDR) as part of the preparation and monitoring posture. When a threat is detected, Huntress automatically quarantines the affected endpoint, isolating it from the rest of the network and preventing lateral movement or further spread before any manual intervention is required. Preparation is the only phase that occurs before an incident and never stops.
2. Identification	The process of confirming, characterizing, classifying, categorizing, scoping, and prioritizing suspected incidents. This phase determines whether an event is a true incident and establishes its type, impact, and severity.
3. Notification	Alerting IRT members to the occurrence of a confirmed incident and communicating status throughout the response. Communication channels, escalation paths, and notification timing are governed by the incident severity level.
4. Containment	Minimizing financial and reputational loss, theft of information, or service disruption. Includes initial public communications and legal notifications as required. The goal is to stop the bleeding without destroying forensic evidence. Huntress AI assists containment by automatically quarantining the affected endpoint the moment a threat is confirmed, isolating it from the network before manual steps begin.
5. Eradication	Eliminating the threat from all affected systems. This includes removing malware, closing unauthorized access paths, patching exploited vulnerabilities, and resetting compromised credentials across the environment.
6. Recovery	Restoring systems and business operations to normal, verified clean states. Includes reputational repair, customer communications, credit monitoring for affected individuals, and legal remediation as appropriate.
7. Post-Incident Activities	Assessing overall response effectiveness through lessons learned. Documenting the incident formally, identifying gaps in detection or response, and incorporating improvements into the plan and security controls.

5. Incident Occurrence and Awareness

The way an incident becomes known will have an impact on the response process and its urgency. Incidents may be discovered through any of the following channels:

8. The organization discovers through its internal monitoring such as Huntress AI detection, SIEM alerts, or IDS/IPS notifications that a cyber incident or data breach has occurred. Huntress will automatically quarantine the affected machine and notify IT immediately.
9. The organization is notified by one of its technology providers, cloud service providers, or managed security service providers of an incident or potential breach.
10. The organization is made aware of a breach through a constituent, customer, employee, or third-party informant who observed or was affected by suspicious activity.
11. The organization and the public are made aware of the incident through news media, public disclosure, or regulatory notification from a third party affected by the same incident.

Regardless of the discovery channel, all suspected incidents must be reported immediately to the Head of Information Technology or the Incident Response Manager. No employee should attempt to investigate or respond to a suspected incident independently without notifying the IRT.

6. Incident Response Process Detail

The following table outlines the detailed steps and approximate timing for each phase of an active incident response. The Preparation phase is excluded from this table as it occurs continuously before any incident.

Phase	Timing	Detailed Steps	Involved Parties
Identification	Hours	1. Identify and confirm whether the suspected or reported incident has occurred and whether malicious activity is still underway. 2. Determine the type, impact, and severity using Appendices B, C, and D. 3. If Huntress has already automatically quarantined the affected endpoint, verify the quarantine is active and confirm no other systems are impacted before proceeding with additional containment.	IT, Huntress (AI detection), and any monitoring service provider
Notification	Hours to 1 Day	4. Inform or activate the IRT based on incident severity as defined in Appendix D. Provide incident type, impact, and all known details. 5. Determine whether Subject Matter Experts (SMEs) are required for Containment, Eradication, or Recovery.	IT and IRT
Containment	Hours to 2 Days	6. Take immediate steps to curtail ongoing malicious activity or prevent repetition. Note: Huntress auto-quarantine may have already isolated the affected system automatically. 7. Redirect public-facing websites if needed. 8. Provide initial public relations and legal responses as required.	IRT, IT, Huntress, SMEs

Phase	Timing	Detailed Steps	Involved Parties
Eradication	Days to Weeks	9. Provide full technical resolution of the threat and all related malicious activity. 10. Address public relations, regulatory notification, and legal issues. 11. Reset all compromised credentials and patch all exploited vulnerabilities.	IT, IRT, SMEs
Recovery	Weeks to Months	12. Recover any business process disruptions and restore normal operations. 13. Address longer-term public relations or legal issues. 14. Apply constituent remedies such as credit monitoring or notification letters as required.	SMEs, IRT
Post-Incident	Months	15. Formalize documentation of the incident including a complete incident timeline. 16. Conduct lessons learned review with the full IRT. 17. Apply learnings to future preparedness and update this plan accordingly.	IRT

7. Communication Methods

Organizational communication resources including email and phone systems may be compromised or unavailable during a severe incident. Primary and alternate out-of-band communication methods using external infrastructure must be established before any incident occurs and documented on the IRT member contact list.

The IRM will designate which communication method will be used at the outset of any activated incident response. All IRT members and individuals involved in incident resolution must use only the designated communication channel during an active incident to prevent information leakage and ensure coordination.

Communication Method	Purpose and Usage
Organizational email (primary)	Standard day-to-day use; may be unavailable during severe incidents
Personal mobile phones (backup)	Out-of-band communication when organizational systems are unavailable
Encrypted messaging app (e.g., Signal)	Secure out-of-band communication for sensitive incident details during active response
Conference bridge (external)	IRT coordination calls when internal phone systems are unavailable
In-person meeting	Primary method for Severity 4 and 5 incidents where electronic systems cannot be trusted

8. Information Recording

Information recording is critical during an incident not only for effective containment and eradication, but also for post-incident lessons learned and any legal action that may follow. Accurate, timestamped records can be essential evidence in law enforcement investigations and regulatory inquiries.

Each member of the IRT is responsible for recording information and chronological references about their actions and findings during an incident using the IRT Incident Record Form in Appendix E. Records must include:

- Date and time of each action or observation
- Name of the individual recording the entry
- System, account, or data set affected
- Actions taken and their outcomes, including any Huntress automated actions such as endpoint quarantine
- Any communications made or received related to the incident

Incident records are considered confidential and legally sensitive. They must be stored securely and access restricted to IRT members and authorized legal counsel only.

9. Incident Response Exercises

The IRT must conduct tabletop exercises to practice the response process on a periodic basis, at minimum annually, so all members are familiar with their responsibilities and the coordination required during an actual incident. Exercises should be conducted every six months per Databarracks best practice guidance.

Tabletop exercises present realistic incident scenarios to the team in a practice setting without actual systems being affected. They provide the opportunity to identify gaps in the plan, test communication procedures, and improve team coordination. Common scenarios to exercise include:

- Ransomware attack encrypting organizational servers and triggering a Huntress automated quarantine
- Data breach involving PII exfiltration
- DDoS attack against internet-facing infrastructure
- Insider threat accessing sensitive data without authorization
- Phishing campaign resulting in compromised executive credentials

Lessons identified from exercises must be documented and incorporated into this plan and the organization's security controls. The IRT is responsible for scheduling, facilitating, and documenting all exercises.

Appendix A — IRT Member Contact List

Contact information for all IRT members must be maintained, circulated to the team, and stored both digitally and in printed form. The printed copy must be stored securely off-system in case digital systems are unavailable during an incident.

Name / Role	Title	Work Phone	Mobile Phone	Alt. Email
Noe Valencia Head of IT / IRM	IT Security Manager	[Work Phone]	[Mobile]	[Alt Email]
[Name] Financial Executive	[Title]	[Work Phone]	[Mobile]	[Alt Email]
[Name] Communications	[Title]	[Work Phone]	[Mobile]	[Alt Email]
[Name] HR Executive	[Title]	[Work Phone]	[Mobile]	[Alt Email]
[Name] Operations Executive	[Title]	[Work Phone]	[Mobile]	[Alt Email]
Huntress MDR	External SME (AI Detection)	[Portal]	[Hotline]	support@huntress.com
[Legal Counsel]	External Attorney	[Phone]	[Mobile]	[Email]
[Cyber Insurance]	External Advisor	[Phone]	[Mobile]	[Email]

Appendix B — Incident Categorization

The following table defines common categories of cyber incidents that the organization may encounter. All confirmed incidents must be categorized using this reference to ensure appropriate response procedures are applied.

Incident Type	Description
Unauthorized Access	An individual or entity gains logical or physical access without permission to an organizational network, system, application, data, or other resource.
Denial of Service (DoS / DDoS)	An attack that prevents or impairs the normal authorized functionality of networks, systems, or applications by exhausting resources such as bandwidth, CPU, or memory.
Malicious Code	Successful installation of malicious software such as a virus, worm, Trojan horse, ransomware, or other code-based malicious entity. Huntress AI will detect and automatically quarantine the affected endpoint upon identification of malicious code activity.
Improper or Inappropriate Usage	A person violates acceptable use computing policies, including unauthorized data access, data theft, or misuse of organizational systems.
Suspected PII Breach	An incident where Personally Identifiable Information (PII) has been or is suspected to have been accessed, exfiltrated, or exposed without authorization.
Suspected Loss of Sensitive Information	An incident involving suspected loss of sensitive information resulting from unauthorized access, malicious code, or improper use where the cause or extent is not yet known.

Appendix C — Incident Impact Definitions

Use the following table to determine the impact level of a confirmed incident across the three security objectives of the CIA Triad. The highest impact level across any objective determines the overall incident impact rating used for severity classification in Appendix D.

Security Objective	General Description	Low Impact	Medium Impact	High Impact
Confidentiality	Unauthorized disclosure of information could adversely affect operations, assets, or individuals.	Limited to a single user or a few computers in an isolated fashion with easy remediation.	Involves a group of users with access to proprietary information. Limited or no external exposure.	A severe breach of proprietary information with significant external exposure.
Integrity	Unauthorized modification or destruction of information could adversely affect operations, assets, or individuals.	Inadvertent or non-malicious alteration or deletion of company data that is easily remediated.	An ongoing improper data alteration of malicious or negligent nature with moderate business impact.	A massive alteration or destruction of company data of a malicious or obstructive nature.
Availability	Disruption of access to or use of information systems could adversely affect operations, assets, or individuals.	Isolated outage affecting a limited number of users for less than 2 hours.	Widespread outage of a primary business system lasting more than 2 hours but less than one day.	Severe outage of business systems lasting one day or more.

Appendix D — IRT Incident Severity and Response Classification Matrix

Use the following matrix to classify confirmed incidents by severity level and determine the appropriate IRT response and activation level.

Level	Typical Characteristics	Example Impact	Response Actions	Activate IRT?
5	DDoS against servers. Active attacks on network infrastructure. Access to internal data by unauthorized parties.	Enterprise-wide attack across multiple departments. Prevents access to systems. Theft of proprietary data.	IRT and IRM direct full response. Huntress MDR notified immediately; auto-quarantine verified. IT, Forensics, and SMEs coordinate remediation. Law enforcement and Legal Counsel engaged.	Full Team Active
4	Affects data or services for a group. Threatens sensitive data. Involves elevated privilege accounts.	Compromised business application. Improper or unauthorized access to data.	IRM, IT, Huntress (MDR), and SMEs coordinate response. Full IRT advised. Legal Counsel notified if PII breach.	Full Team Informed and Advised
3	Affects a single individual with significant sensitive data. May include PII.	Employee computer or account with sensitive data access compromised. Physical theft of device.	IT or IRM coordinates. Huntress auto-quarantine checked and confirmed if triggered. IRT members informed. Legal Counsel notified if PII breach.	Primary Team Informed
2	Affects a group with no sensitive data involved.	Compromise of an account or shared folder with no sensitive data.	IT coordinates response. IRM advised, IRT informed. Huntress portal reviewed for related alerts. IT documentation records findings.	Primary Team Informed
1	Affects a single individual with no sensitive data. Focus is correction and prevention.	Compromised computer with no sensitive data.	Documentation of issue and findings. IT/IRM coordinate remediation.	No
0	Very minor or undetermined incident with no practical follow-up needed.	Impaired computer requiring AV scan or password reset.	Documentation through normal IT support processes. Reset passwords as needed.	No

Appendix E — IRT Incident Record Form

Each IRT member must use this form to record all actions, observations, and communications during an active incident. Accuracy and timestamps are critical for post-incident analysis and any potential legal proceedings. Include any automated actions taken by Huntress such as endpoint quarantine events.

Incident:	Discovery Date:	Severity Level:
------------------	------------------------	------------------------

Recorded By:	IRT Role:
---------------------	------------------

Date / Time	Recorded Information and Events

Document Version History

Version	Date	Changes / Notes
1.0	March 22, 2026	Initial release — Noe Valencia
1.1	March 28, 2026	Added Huntress AI MDR including automated endpoint quarantine capability